Evaluating the Security Posture of Default IaaS Configurations in Azure vs Google Cloud

Akshaykumar Kathirvelu – Cloud Security Assessment Lead (IAM, Network Security & Recommendations)

Agenda

- Scope & Objectives
- Completed Work
- IAAS Configs
- Cloud Storage & IAM
- Logging & Monitoring
- Recommendations & Conclusion

Project Scope & Objectives

Infrastructure Vulnerabilities

Assess default infrastructure configurations for potential security gaps.

Storage Security

Evaluate storage policies and access controls to prevent unauthorized data access.

Logging & Monitoring

Compare default logging and monitoring capabilities across platforms.

Risk Analysis

Provide actionable recommendations to strengthen cloud security posture.

Why this matters

- Cloud platforms are secure, but defaults aren't always safe.
- Many organizations deploy resources without reviewing security settings.
- OWASP top 10 considers security misconfiguration to be the 5th most common security risk to web applications.
- Our goal: Evaluate how Azure and GCP handle default security for IaaS.

Completed Work

- Deployed VMs and storage buckets with default settings in Azure and GCP.
- Analyzed:
  - Public exposure
  - Identity & access
  - Storage encryption
  - Logging & monitoring
- Compared security tools and service identity mechanisms.

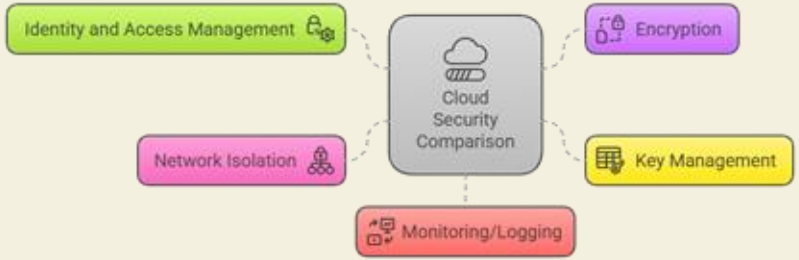
IaaS Configuration (VM)

Virtual machines: An overview

As organizations increasingly adopt cloud infrastructure, evaluating the default security posture of Infrastructure-as-a-Service (IaaS) offerings becomes critical. This study focuses on comparing Microsoft Azure and Google Cloud Platform (GCP), two of the most widely used cloud providers, specifically analyzing how they configure virtual machines (VMs) and associated security controls by default.

The comparison covers key security domains including Identity and Access Management (IAM), encryption (at rest and in transit), key management, network isolation, and monitoring/logging capabilities. While both Azure and GCP provide enterprise-grade tools, their default configurations often lack essential visibility or enforcement such as disabled flow logs, broad service account privileges, or minimal audit tracking.

By provisioning and evaluating VMs on both platforms, this analysis identifies the strengths and limitations of each environment. The findings support actionable recommendations for hardening IaaS deployments, improving compliance alignment, and adopting a zero trust security model. Ultimately, the goal is to help organizations build secure, scalable, and resilient cloud infrastructure beyond the defaults.



Virtual Machine Setup

Feature	Azure	GCP
VM Creation Portal	Azure Portal	GCP Console
Free Tier Option	B1s VM	e2-micro VM
OS Options	Windows, Linux	Windows, Linux
Networking	VNet, NSG (default disabled logging)	VPC (logging disabled)
Authentication	SSH Key / Password	SSH Key / Browser-based SSH
Monitoring	Boot diagnostics (optional)	Cloud Logging (optional)

Virtual Machine Setup - Monitoring, Logging, and Compliance

Feature	Azure	GCP
Default Monitoring	Azure Monitor, Log Analytics	Cloud Monitoring, Cloud Logging
SIEM Integration	Microsoft Sentinel (native)	Chronicle (Google-native SIEM, or integrate with SCC)
Audit Logs	Activity Logs, Diagnostic Settings	Cloud Audit Logs (Admin, Access, Data)
Flow Logs	NSG Flow Logs (disabled by default)	VPC Flow Logs (disabled by default)
Retention	30–90 days default, extendable	30 days default, can route logs to Cloud Storage
Compliance Tools	Azure Policy, Secure Score, Compliance Manager	Org Policy, SCC Recommendations, Access Transparency

Virtual Machine Setup - Security Configurations (Default vs Hardened)

Security Element	Azure	GCP
Access Control	Azure AD + RBAC + Managed Identities	IAM + Service Accounts + Object-Level Control
Encryption at Rest	AES-256, CMK/PMK, Double Encryption Option	AES-256, CMEK, CSEK
Encryption in Transit	TLS 1.2+, HTTPS enforced	TLS 1.2+, Service-to-Service encryption
Key Management	Azure Key Vault (CMK, CSK, HSM support)	Cloud KMS & Cloud HSM
Threat Detection	Microsoft Defender for Cloud	Security Command Center
Logging Defaults	NSG Flow Logs off by default	VPC Flow Logs off by default

Cloud Storage & IAM

Storage Security: Access & Encryption

Google Cloud Storage

IAM policies down to object level. Public access **disabled** by default; automatic AES-256 encryption.

Azure Blob Storage

Uses RBAC and SAS for access. Public access **enabled** by default; encryption with AES-256 at rest.

Key Differences

Azure integrates tightly with AD; GCP offers finer granularity and Workload Identity Federation for secretless authentication.

Storage Security: Access & Encryption

- **Azure:** Encryption at rest (AES-256), TLS 1.2+ in transit, Azure AD for authentication, supports SAML, OIDC, OAuth 2.0, and Managed Identities.
- **GCP:** Automatic AES-256 encryption, TLS 1.2+, IAM Service Accounts, supports SAML, JWT, OAuth 2.0, and Workload Identity Federation.
- **Key Differences:** GCP offers Access Transparency and VPC Service Controls; Azure supports double encryption and relies on managed identities.

Key Management: Storage & Control

Azure Key Vault

Centralized management of keys and secrets, supports PMKs, CMKs, and CSKs. Integrates with RBAC and Azure AD.

GCP Cloud KMS/HSM

Software and hardware-backed key storage, supports Google-managed, CMEK, and CSEK. Project-based IAM model.

Visibility & Isolation

Azure offers more visibility controls; GCP enables ephemeral keys and enhanced isolation via VPC Service Controls.

Default Configuration Risks – Azure

- Platform-controlled keys are used by default, limiting customer visibility.
- Over-permissioned service identities create a wider attack surface.
- Double encryption is not enabled by default.
- Public access settings may be missed if not expressly disabled.

Default Configuration Risks – GCP

- Customer managed encryption keys (CMEK) are not enabled by default (Google-managed keys are used)
- Default service accounts often include extensive project-level rights.
- Service accounts may be misused if not restricted.
- Data Access Audit Logs are disabled by default, limiting visibility into who accesses stored data.

Logging & Monitoring

Logging & Monitoring: An overview

- **Threat Detection:** Robust logging enables early threat detection and faster response times, significantly reducing the risk of data breaches.
- **Compliance:** Continuous monitoring supports compliance with regulatory standards, helping avoid costly legal penalties.
- **Misconfiguration:** Default IaaS settings often contain misconfigurations that can leave systems vulnerable to unauthorized access and security threats, logging can assist in identifying these vulnerabilities.

Logging & Monitoring - Azure

- **Key Azure Tools:** Azure Monitor, Activity Logs, Diagnostic Logs, Defender for Cloud, and Sentinel are crucial for logging.
- **Azure Strengths:** Azure provides deep native integration and robust SIEM capabilities, enhancing overall cloud security effectiveness.
- **Identified Gaps:** Default settings for Network Security Group flow logs and limited log retention may hinder security performance.

Logging & Monitoring - GCP

- **Key GCP Tools:** Cloud Logging, Cloud Monitoring, Audit Logs, and Security Command Center are essential for visibility and analysis.
- **GCP Strengths:** GCP provides centralized monitoring across services with real-time log ingestion and customizable retention, simplifying detection and response.
- **Identified Gaps:** Defaults like disabled VPC flow logs and limited audit logging may leave blind spots, increasing the risk of undetected threats.

Logging & Monitoring - Gaps & Recommendations

Gaps	Azure	GCP	Recommendations
Logs Disabled by Default	Network Security Group (NSG) flow logs are off by default	VPC flow logs and API call logs are disabled by default	Enable flow logs to ensure visibility into network traffic and detect anomalies.
Broad Alert Thresholds	Defender for Cloud may trigger excessive alerts without tuning	Cloud Monitoring can produce alert fatigue if thresholds are not adjusted	Customize alert rules to minimize noise and focus on critical events
Short Log Retention	Default log retention is 90 days	Default log retention is 30 days, extended with the use of cloud storage	Increase log retention to meet compliance standards (paid)

Recommendations & Conclusion

Recommendations for Secure Cloud Adoption

Customize IAM Roles

Limit permissions, enforce least privilege, and review roles regularly.

Enhance Logging & Encryption

Enable key logging features, use customer-managed keys, and enforce rotation policies.

Integrate SIEM & Compliance

Leverage SIEM tools, apply CIS benchmarks, and conduct regular compliance testing.

Customize Configuration

Do not rely on the default configurations of any IaaS, customize and implement security controls that best meet your needs.

Conclusion

Critical Gaps Remain

Default configurations in Azure and GCP are not sufficient for enterprise security. Key gaps include privilege management, key control, and network visibility and much more.

Tailored Enhancements Needed

Custom IAM, encryption policies, and proactive logging are essential for risk reduction and compliance.